SPOTIFY'S DATA & AI GOVERNANCE PROJECT

1. *Data & AI Maturity Assessment* Report

> *Nicolas Pichon --- AIA RNCP 38777 / BC01 / Step 1 / v22 --- 2026/10/15.*

1.1. Évaluation de la maturité *Data/AI* chez *Spotify*

Les tableaux ci-dessous évaluent la maturité de la gouvernance des données et des modèles d'IA chez Spotify, d'après les informations fournies par le *business case* [R2] et selon la méthodologie d'évaluation encadrée par le *DMAT Australien* [R1].

> Les domaines *DO*, *MRD*, *MDT* absorbent les questions de [R1] sans correspondance dans [R3].

En bref : Spotify a une capacité analytique relativement avancée en analytique (moteurs d'inférence en production) mais la gouvernance des données proprement dite reste faible. Un cadre de gouvernance est établi (rôles définis, outils identifiés) mais il n'est pas encore déployé (pas d'audits, pas d'installations, pas de déploiement des politiques). Le niveau moyen de maturité selon l'échelle de valeurs donnée par [R1] reste proche de *1* (gouvernance locale, dispersée, réactive).

1.1.1. Evaluation des niveaux de maturité selon [R1]

Dimension	N (*)	Justification
Data Governance	1	*Cadre de gouvernance* unifié non défini ; Rôles partiellement définis mais non implémentés.
Data Quality	1	*Qualité* reconnue comme risque majeur ; A venir : *Cleansing*, *validation*, *monitoring*
Data Architecture	1	Infrastructure sophistiquée (data lakes, cloud, temps réel) ; Absence de gouvernance, de méthodologie unifiée, de prise en compte de la création de valeur.
Data Operations	1	Pas de documentation de l'exploitation quotidienne : politiques de sécurité, usage, qualité, cycle de vie des actifs, sauvegarde, restauration, capacité, pannes, amélioration continue.
Compliance	1	Pas de vérification systématisée de la conformité ni de gestion spécifique des réglementations de l'IA.
Data Usage & Accessibility	2	Usage décisionnel local, limité par le silotage ; Exploitation orientée client (personnalisation, recommandation).
Data Security	1	Enjeu reconnu ; Dispositifs non documentés : classification, chiffrement, réponse aux incidents.
Data Literacy	2	Culture *data-driven*, littératie de base, spécialistes data reconnus ; Montée en compétence non structurée ; Investissements non documentés.
Master & Reference Data	1	Domaines de master et reference data non documentés.
Metadata	1	Pas de gouvernance des métadonnées, de lineages, de révision des standards.
Data Integration	1	Besoin d'intégration compris ; Silotage par département ; Usage actuel opportuniste ; Absence de processus formel.
Analytics & BI	2	Moteur de recommandation, analytique temps réel, big data, personnalisation ; Limité par la qualité des données d'entrée et l'absence de gouvernance de l'IA

> (*) *Valeurs des niveaux de maturité : 0: unmanaged, 1: initial , 2: developing, 3: defined, 4: measured & managed , 5: optimized.*

1.1.2. Plan d'actions

Dimension	Actions
Data Governance	Définir les autorités manquantes (**) ; Implémenter l'organigramme ; Publier la politique d'entreprise.
Data Quality	Définir les règles de qualité ; Outiller profiling, cleansing, monitoring continu, validation à l'entrée.
Data Architecture	Aligner l'architecture sur les cas d'usage de valeur ; Documenter les modèles ; Appliquer les méthodologies SDLC, DataOps, ModelOps.
Data Operations	Documenter les politiques de gestion des actifs ; Formaliser cycle de vie, sauvegarde, restauration, reporting des pannes ; Prioriser les requêtes selon la valeur créée ; Instaurer l'amélioration continue.
Compliance	Nommer un DPO ; Intégrer la vérification dans les processus ; Programmer des audits ; Gérer consentement et droits ; Aligner les paiements sur les réglementations ; Gérer la conformité IA.
Data Usage & Accessibility	Déployer un catalogue ; Définir les accès par rôle ; Élargir l'usage décisionnel au-delà des équipes techniques ; Encadrer des services BI en accès libre.
Data Security	Contrôler l'accès par rôle ; Définir les plans de réponse aux incidents ; Outiller le chiffrement ; Tracer les évènements de sécurité ; Auditer.
Data Literacy	Former à la gouvernance et à la qualité ; Investir dans la littératie de manière organisée et ciblée ; Définir une stratégie de rétention des spécialistes data ; Partager les responsabilités data entre les métiers.
Master & Reference Data	Identifier, modéliser, documenter les domaines de master et de reference data ; Concevoir une source unique de vérité partagée ; En assurer un usage transversal cohérent.
Metadata	Capturer les métadonnées (glossaire, attributs standardisés) ; Assurer leur traçabilité de la source à l'usage (lineage) ; Définir la revue des standards par la gouvernance.
Data Integration	Établir des processus d'intégration (approbation, connexion, maintenance) ; Intégrer les systèmes silotés ; Gérer les biais des sources.
Analytics & BI	Gouverner l'IA (biais, conformité, éthique, explicabilité) ; Contrôler la qualité des données d'entraînement ; Mesurer la valeur générée.

> (**) *Data Governance Committee, Data Owners, Data Stewards, Data Custodians, Model Owner, Model Risk Manager*.

1.2. Identification des enjeux majeurs de la gouvernance

Six enjeux majeurs ont été identifiés, énumérés ci-dessous par ordre de criticité.

Ces enjeux sont déjà identifiés dans le *business case* [R2] (à l'exception de l'enjeu E5 - *Gouvernance de l'IA*). Ils y sont déjà plus ou moins définis, et présentés comme des chantiers à venir. Des critères d'avancement peuvent être dérivés du *DMAT* [R1] pour évaluer chacun de ces chantiers (sauf la déclinaison multi-juridictionnelle de l'enjeu E3).

La question d'un modèle de déploiement de la gouvernance à l'échelle mondiale, capable de concilier cohérence globale et autonomie locale, relève d'un choix organisationnel transversal et n'est pas retenue comme enjeu majeur. Elle sera traitée en phase de mise en œuvre.

E1. Décompartimenter les données

Les départements de métiers, en gérant leurs données de manière indépendante, compartimentent les données en silos [R2]. Ce fonctionnement produit des vues incohérentes ou incomplètes d'un même utilisateur ou d'un même contenu et crée des angles morts dans la décision [R2].

L'ampleur du chantier pour corriger ce dysfonctionnement est importante. Il implique à la fois d'établir une source unique de vérité pour les entités partagées, de déployer une plateforme et un catalogue de données communs, de définir un processus formel d'ajout et de maintenance des sources, standardiser formats et définitions, d'attribuer des responsabilités, d'instaurer et d'implémenter des règles d'accès par rôle. C'est un programme extrêmement structurant et transverse à toute l'organisation.

E2. Maîtriser la qualité des données

[R2] identifie le contrôle de la qualité des données comme un enjeu majeur. Le document évoque des « données inexactes » et des « métadonnées obsolètes » qui dégradent les recommandations mais ne définit pas la qualité des données de manière opérationnelle. En amont des processus de nettoyage, de monitoring et de validation, recommandés à la fois par [R1] et par [R2], l'enjeu implique donc également un travail important de définition des règles de qualité des données.

E3. Maîtriser la mise en conformité réglementaire dans un contexte multi-juridictionnel

La mise en conformité réglementaire est identifiée comme un enjeu majeur dans [R2]. Les obligations à couvrir sont nombreuses : gestion du consentement explicite, traitement des demandes des personnes concernées, notification des violations sous 72 heures.

La difficulté spécifique de l'enjeu est sa déclinaison multi-juridictionnelle, la société opérant sous des régimes juridiques hétérogènes : GDPR (UE) [A1], CCPA (Californie)[A2], PDPA (Singapour)[A3], auxquels s'ajoutent les réglementations spécifiques concernant la gouvernance de l'IA [R2]. Il s'agit de satisfaire simultanément les exigences de chaque régime sans dégrader la cohérence d'ensemble.

E4. Garantir la vie privée et l'usage éthique des données

[R2] identifie la protection de la vie privée comme un objectif à part entière et engage l'entreprise sur un usage éthique aligné sur ses valeurs. [R1] traite l'adoption de principes d'éthique des données comme un critère de maturité. Dans les deux documents, cet enjeu est traité distinctement des enjeux de conformité, car un traitement peut être licite et néanmoins intrusif (c'est le cas lorsque l'analyse des écoutes permet d'inférer des préférences que l'utilisateur n'a pas déclarées).

En amont d'un contrôle effectif sur ses données (accès, modification, suppression) et de l'anonymisation de ses données chaque fois que c'est possible, l'utilisateur attend également une grande transparence sur les processus de collecte, sur l'usage et sur le partage de ses données.

E5. Gouverner spécifiquement les données IA

Le moteur de recommandation de *Spotify* repose sur des modèles de *machine learning* en production, mais [R2] n'aborde pas leur gouvernance proprement dite : tracer les données d'entraînement, détecter les biais algorithmiques, organiser la responsabilité des modèles en production et de leur approbation (du point de vue de la conformité réglementaire et éthique).

[R2] reconnaît ces enjeux comme objectifs à atteindre, mais pas comme pratiques établies. [R1] confirme le retard en identifiant explicitement ces questions comme des critères de maturité.

E6. Accompagner la montée en compétences *data*

Le développement de *Spotify* autour d'une culture *data-driven* implique une *littératie* de base aux données. Néanmoins [R2] souligne qu'une culture partagée de la gouvernance, de la qualité et de la conformité reste à construire. La responsabilité de la donnée n'est pas répartie entre les métiers, et la résistance au changement est identifiée comme un risque de la mise en œuvre.

Références

Ressources

- [R1] *Australian Government Data Maturity Assessment Tool* (2026)
- [R2] Spotify Business Case
- [R3] Data Maturity Assessment Template
-

Documents applicables

- [A1] *General Data Protection Regulation* - Règlement (UE) 2016/679, 27 avril 2016. JO L 119, 4.5.2016.
- [A2] *California Consumer Privacy Act of 2018*, Cal. Civ. Code § 1798.100, amendé / CPRA (Prop. 24, 2020).
- [A3] **[PDPA]** *Personal Data Protection Act 2012* (No. 26 of 2012), Singapour, amendé en 2020.